

Is Your Community Bank's Insurance Exam-Ready?

Ten questions your cyber policy, fidelity bond and D&O should be able to answer.

Examiners are asking harder questions about cyber insurance: not whether you have it, but whether the board knows what it covers, whether the limits match your risk assessment, and whether the cyber policy, the fidelity bond and the D&O work together when a wire fraud, a ransomware attack or a vendor outage hits. Most of these answers are not in one policy, and the gaps usually sit in the seams between two policies rather than inside either one.

This checklist is drawn from my insurance audits of community banks. Mark whether you can answer each question with confidence, from the policy language rather than a renewal summary.

1 BOARD GOVERNANCE

1. Has your board reviewed what the cyber policy covers and excludes, not just approved the premium?

Cyber insurance is the area examiners are scrutinizing most. They want evidence of board-level coverage review, not broker reliance.

☐ Yes ☐ No ☐ Not Sure

2. Is there a documented rationale connecting your coverage limits to your risk assessment?

A \$1M cyber policy on a \$500M bank will draw examiner questions. What the examiner wants is the reasoning behind the number: which loss scenarios the board considered, what they would cost, and why your limit covers them.

☐ Yes ☐ No ☐ Not Sure

2 POLICY COVERAGE

3. Does your fidelity bond's social engineering sublimit reflect your wire transfer volume?

Check fraud hits community banks often, but it mostly falls below your deductible and gets absorbed as an operating loss. Wire fraud tends to be much larger, and it lands on the fidelity bond. Many bonds carry sublimits that no longer reflect what the bank moves in a day, and no cyber policy sits behind the bond.

☐ Yes ☐ No ☐ Not Sure

4. If ransomware took your core banking vendor down for a week, would your cyber policy pay the lost income?

Most banks run on a single core platform, and this is the outage that halts the bank without anyone touching its own network. The trigger decides this before the limit does. Some policies write dependent business interruption for a system failure at the vendor only, which means a ransomware attack there never triggers your coverage. Coverage that responds at a modest sublimit is worth more than a high limit that never responds. Read the trigger wording first, then the sublimit against a full week of lost income, then the waiting period and whether the policy requires a written contract with the vendor.

☐ Yes ☐ No ☐ Not Sure

5. Does your wire verification procedure match what your bond requires, word for word?

Most bonds condition social engineering coverage on a call back above a stated threshold to a pre-established number, with a record kept of each call. That is a condition precedent. Miss it, or fail to evidence it afterward, and the carrier declines. Compare this endorsement to what your wire desk does. This gap closes with a procedure change, not a premium.

☐ Yes ☐ No ☐ Not Sure

6. Have you compared your carrier's security warranty requirements to your most recent IT audit?

Applications now ask you to warrant specific controls: MFA on remote access and privileged accounts, tested offline backups, endpoint detection. Those answers become part of the policy. If your last IT audit found an exception, a service account outside MFA or a system carved out of EDR, the warranty no longer matches the environment. Compare the signed application against the audit findings.

☐ Yes ☐ No ☐ Not Sure

3 POLICY INTERACTIONS

7. Your bond has two coverages that could pay a wire fraud loss. Do you know the gap between them?

Find your computer fraud or electronic crime limit on the bond declarations page, then find your social engineering or false pretenses limit. On most bonds I review, the computer fraud limit is 10x to 20x the social engineering limit. Which one pays is decided by forensics after the loss, on whether the attacker entered a system or simply sent a convincing message. Same money gone; recovery different by millions.

☐ Yes ☐ No ☐ Not Sure

8. After a data breach, which policy covers your directors' personal liability? Are you sure?

Most D&O forms exclude cyber-related claims to some degree. Where the exclusion reaches your directors, the answer is the cyber policy, and they are covered there. But that changes what they can draw on. Under the D&O, the board has a limit of its own. Under the cyber policy, the board shares one limit with forensics, notification and business interruption, and the breach spends it first.

☐ Yes ☐ No ☐ Not Sure

9. An examiner names a director personally and asks for an interview. Nothing has been filed. Do you know who pays that director's lawyer?

At this stage there is no lawsuit, no demand, and usually no "claim" as either policy defines it, so neither one turns on. What responds is a separate D&O coverage part, written as investigative costs or pre-claim inquiry. On every program I have reviewed it was capped at a token amount, offered but never purchased, or absent from the form. Find it on your D&O declarations before you need it.

☐ Yes ☐ No ☐ Not Sure

10. If the group that encrypts your systems turns out to be sanctioned, does your board already know that no policy pays the ransom?

This is the one place where all three policies can fail together. The cyber sanctions clause blocks the payment, the bond's OFAC advisory blocks any extortion agreement behind it, and the D&O cyber exclusion can reach the board's investigation defense if regulators question how the decision was made. A bank already lives under BSA/AML enforcement, so an OFAC violation here is judged more harshly than it would be elsewhere. No endorsement fixes this. The block is federal law, not policy language. Put OFAC screening in the response playbook, and confirm business interruption and breach response still pay when the ransom cannot.

☐ Yes ☐ No ☐ Not Sure

A **Risk Intelligence Report** answers all ten of these questions for your specific policies, and more. It reads your cyber, bond, and D&O policies together, maps which policy responds to common cyber scenarios, identifies the gaps, and suggests how to fix them, with specific language and estimated costs. You get board-ready documentation before your next examination.

I am happy to check yours.

Joerg Proeve | Breezy Risk | joerg@breezyrisk.com | (717) 490-7670

I don't place insurance. I audit it.